



AI SECURITY

10 Core Skills for Defending AI Agents

Prepared By: Maisam Shaikh Ibrahim

Why AI Security?

As LLMs move from chatbots to autonomous agents, they create an entirely new attack surface.



A New Attack Surface

Agents that call tools, browse the web, and take real actions can be manipulated through prompts, documents, or tool results, not just malicious code.



Traditional Security Doesn't Cover It

Firewalls and antivirus don't stop jailbreaks, prompt injection, or a model leaking its own instructions or private data.



Layered Defense Is Essential

No single control catches everything, real AI security combines input filtering, output validation, access control, and continuous testing.

The 10 Skills

1



PII Masking &
Data Redaction

2



Human-in-the-Loop
Gatekeeping

3



Indirect Prompt
Injection Defense

4



Deny-by-Default
Capability Mapping

5



Outbound Response
Validation

6



System Prompt
Protection

7



Adversarial
Red-Teaming

8



Agentic Tool
Invocation Security

9



Structural Error
Masking

10



Rate Limiting &
Token Throttling



SKILL 01

Automated PII Masking & Redaction

What it is

Automatically detects and masks personal data, emails, phone numbers, SSNs, credit cards, before it reaches a user, a log file, or storage.

Why we need it

LLM outputs can surface sensitive data from earlier context or retrieved documents. Without redaction, that data can leak into logs or reach people who shouldn't see it, creating privacy and compliance risk.

Tools & Technologies

Microsoft Presidio

spaCy NLP

LLM Guard

Regex-based scanners

What it is

Pauses an AI agent before it executes a high-impact action (sending an email, deleting data) and requires explicit human approval first.

Why we need it

Agents reason over untrusted input, so a manipulated agent could take irreversible real-world actions. A human approval gate is a circuit breaker, even a compromised agent can't act without sign-off.

Tools & Technologies

NeMo Guardrails

Workflow/notification APIs (Slack, email)

Custom approval services



SKILL 02

Context-Aware Human-in-the-Loop Gatekeeping



SKILL 03

Defending Against Indirect Prompt Injection

What it is

Tests and defends against instructions hidden inside content a model retrieves — a document, webpage, or email — rather than in the user's own message.

Why we need it

In RAG pipelines and browsing agents, an attacker never needs direct access to the system — planting a hidden instruction in content the model will read is enough to attempt a hijack.

Tools & Technologies

LLM Guard (PromptInjection scanner)

garak

RAG input sanitizers

What it is

Explicitly allowlists every tool an AI agent may use and the exact argument shapes it may call them with — anything not listed is automatically rejected.

Why we need it

As agents gain more tools over time, it becomes easy to lose track of what they can actually do. Denying by default means only pre-approved actions are ever possible in the first place.

Tools & Technologies

JSON Schema validation

Tool/capability registries

Least-privilege IAM



SKILL 04

Deny-by-Default Capability Mapping



SKILL 05

Outbound Response Validation & Safety Filters

What it is

Scans an LLM's generated response before it reaches the user — checking for toxic content, leaked sensitive data, or policy violations.

Why we need it

A model can occasionally produce an unsafe or non-compliant response even with good training. An independent output-side check catches this without relying solely on the model's own judgment.

Tools & Technologies

Llama Guard 3

NeMo Guardrails

LLM Guard output scanners

What it is

Tests whether an LLM's hidden system prompt — its role, restrictions, and internal configuration — can be extracted through direct or indirect prompting.

Why we need it

A leaked system prompt gives an attacker a roadmap to bypass a model's restrictions, and may expose confidential business logic embedded in the instructions.

Tools & Technologies

Prompt-leak test suites

garak

Custom leak detectors



SKILL 06

Post-Inference System Prompt Protection



SKILL 07

Red-Teaming LLMs (Adversarial Testing)

What it is

Systematically probes an LLM with large batteries of known jailbreak and adversarial prompts to discover weaknesses in its safety behavior.

Why we need it

Manually testing one jailbreak at a time doesn't scale and misses techniques you haven't thought of. Automated red-teaming turns safety testing into a repeatable, measurable process.

Tools & Technologies

garak (NVIDIA)

PyRIT (Microsoft)

Adversarial prompt libraries

What it is

The full layered control set governing the moment an agent decides which tool to call: allowlisting, argument validation, scoped credentials, approval gates, and audit logging.

Why we need it

This is the highest-risk point in an agentic system — a single successful manipulation here can turn an agent into a 'confused deputy' taking real, harmful actions.

Tools & Technologies

NeMo Guardrails

JSON Schema

AWS STS / scoped IAM

Audit logging / SIEM



SKILL 08

Securing Agentic AI Tool Invocation



SKILL 09

Structural Error Masking & Exception Management

What it is

Ensures that any internal failure inside a security-critical function never leaks internal details, and always defaults to a safe denial rather than an accidental allow.

Why we need it

If a bug or unexpected input crashes a policy-enforcement function, the worst outcome is for that ambiguity to be treated as permission. Failing closed guarantees a bug can never grant unauthorized access.

Tools & Technologies

Structured try/except policy wrappers

Centralized logging

SIEM alerting

What it is

Caps how much a single user or request can demand from an LLM system — limiting request volume over time and capping the length of any single prompt.

Why we need it

Without limits, a single actor can drive up cost, degrade service for others, or use high-volume systematic querying as a building block for model-extraction attacks.

Tools & Technologies

API gateways

LLM Guard TokenLimit scanner

Rate-limiter middleware



SKILL 10

User Rate Limiting & Token Throttling



Defense in Depth

No single control secures an AI system. Input filtering, output validation, access control, human oversight, and continuous adversarial testing work together, each catching what the others might miss.



These 10 skills form a practical foundation for securing modern LLM and agentic AI systems.